

Security Incident Report

Barcoo Regional Council

Executive Summary

Between 10–12 June 2026, Magiq Software detected and responded to a security incident affecting the InfoXpert legacy reporting system (IXReports) hosted on Barcoo Regional Council's infrastructure. An attacker exploited a vulnerability in the reporting system to obtain database credentials, then used those credentials to gain direct access to the SQL Server and execute commands at the operating system level.

The affected server (RM02) was isolated promptly. Investigation confirmed the attacker's access was contained to that machine. No domain accounts, other servers, or Active Directory data were accessible from the compromised position. All identified vulnerabilities have been resolved and the system has been hardened.

What Happened

Step 1 — File Access via the Reporting System

The attacker exploited a flaw in the IXReports file download feature. The system accepted a filename directly from the browser request without checking whether it was valid or safe. By crafting a malicious request, the attacker was able to retrieve files from the server that should not have been accessible — including configuration files that contained database credentials.

Step 2 — Direct Database Server Access

Using the credentials obtained in Step 1, the attacker connected directly to the SQL Server instance. The account in question had been granted administrator-level privileges on the database server, which gave the attacker full control over the database environment.

Step 3 — Operating System Command Execution

With administrator access to SQL Server, the attacker enabled a built-in SQL Server feature that allows operating system commands to be run from within the database. This gave them the ability to read files on the server's local file system.

What Was at Risk

The SQL Server service account used for command execution operates under strict Windows restrictions. Investigation confirmed the following:

Data and assets accessible from the compromised position:

- Database credentials stored in configuration files on RM02
- Content of databases hosted on the SQL Server instance

- Other connection string credentials stored in files on RM02
- Files on RM02's local file system readable by the SQL Server service
- Local user account names on RM02

Data and systems NOT accessible (confirmed by absence of corresponding security alerts):

- Windows account passwords or password hashes — the service account is blocked from those registry locations
- Cached domain user credentials — the service account has no access to the Windows credential store
- Credentials or data on other servers — the service account has no domain identity and cannot authenticate to remote machines
- Active Directory — no domain access from a virtual service account

The blast radius of this incident is confirmed to be limited to RM02.

How It Was Contained

Upon detection of suspicious remote login activity, RM02 was isolated from the network. This was the correct response and prevented any further access or lateral movement.

What Was Fixed

IXReports — File Download Vulnerability

The file download feature in the reporting system now validates and restricts all filenames supplied by browser requests. Files outside the permitted scope cannot be requested.

IXReports — SQL Injection Vulnerabilities

A separate review of the reporting system identified three additional vulnerabilities in the way database queries were constructed from user-supplied input. These vulnerabilities could have allowed an attacker to manipulate database queries to retrieve unauthorised data.

All three were resolved:

- User-supplied filter operators are now checked against an approved list — anything outside that list is rejected
- User-supplied filter values are now sanitised before being used in queries
- Date inputs are validated to ensure they contain only numeric values
- Report configuration fields are validated to permit only safe identifiers

Publishing Portal — TLS Hardening

A dependency update was applied to the Publishing Portal, enforcing TLS 1.2 and eliminating exposure to older, weaker encryption protocols (TLS 1.0 / 1.1).

Current Status

System	Finding	Status
IXReports	File traversal via download feature	Resolved
IXReports	SQL injection — 3 vectors (Critical / High)	Resolved
Publishing Portal	TLS downgrade exposure	Resolved

Outstanding Recommendations

1. **Database access review** — Audit all SQL accounts used by InfoXpert applications. No application account should hold administrator-level database privileges. Accounts should be granted only the minimum permissions needed.
2. **RDP access audit** — Review Windows login event logs on RM02 to establish the full timeline of remote access and confirm whether any data was accessed or exfiltrated during the incident window.